Schneider Electric Firmware Threat Brief

Schneider Electric (Modicon + EcoStruxure, non-APC) Firmware Attack Surface & Detection Brief

Scope: Schneider Electric's industrial portfolio excluding APC UPS subsidiary, spanning ~30+ product families across Modicon PLCs, EcoStruxure engineering software, Triconex SIS, Citect SCADA, and Sepam protective relays. **Firmware extraction is pending** — no binaries have been unpacked from `firmware-staging\Schneider\` at the time of writing; this brief is research-only and combines CVE/PSIRT history, Claroty/Forescout/Dragos research, and US-CERT/CISA advisory traffic to prime the future extraction queue. Architecture groups: 6. Unique-hash count: 0 (extraction pending).

Purdue layer mapping: Modicon PLCs (Group A) live at **Purdue L1 (Basic Controllers)**, with Sepam relays (in Group E) also at L1. EcoStruxure Control Expert / Operator Terminal Expert (Group B), Citect SCADA (Group D), and EcoStruxure Power Operation (in Group E) live at **Purdue L3 (Site Operations)**. Triconex SIS (Group C) is the **Safety Systems** branch (parallel to L1) — TRITON's target. EcoStruxure cloud agents (Group F) sit at the **Purdue L3.5 (IT/OT Boundary)** with L4 cloud egress. See purdue-l1-basic-controllers-brief.md, purdue-l3-site-operations-brief.md, purdue-safety-systems-brief.md, and purdue-l35-it-ot-boundary-brief.md for cross-vendor views.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A	L1 Basic Controllers	Modicon M340 / M580 / Quantum / Premium / Momentum	VxWorks (M340/Quantum/Premium), Linux on ePAC coprocessor (M580), UMAS over Modbus/TCP 502	research only
B	L3 Site Operations (EWS)	EcoStruxure Control Expert (Unity Pro), Operator Terminal Expert (Vijeo Designer)	Windows engineering workstation, .NET + native, project files `.stu` / `.xef` / `.zef`	research only
C	Safety Systems (parallel to L1)	Triconex Tricon v10/v11, Trident, Tri-GP	Proprietary RTOS on MP/IOP, TriStation 1131 protocol UDP/1502, key-switch PROGRAM/RUN/REMOTE	research only
D	L3 Site Operations	Citect SCADA / Plant SCADA	Windows server, CTAPI, ANL files, embedded Cicode runtime	research only
E	L3 SCADA (Power Operation / PME) + L1 IED (Sepam, incl. IEC 61850 station bus)	EcoStruxure Power Operation / Power Monitoring Expert; Sepam 20/40/60/80 relays	Windows SCADA stack; Sepam = ARM/firmware over Modbus, IEC 61850 on optional MES card	research only
F	L3 on-prem edge agent + L3.5 IDMZ traversal +	EcoStruxure cloud agents (Augmented Operator	x86/ARM Linux gateway + Azure IoT Hub egress (TCP 443/8883)	research only

Class	Purdue layer	Products	Stack	Catalog depth
	L4/L5 cloud egress (Azure IoT Hub)	Advisor, Asset Advisor, Secure Connect Advisor)		

Group A — Modicon PLCs (M340 / M580 / Quantum / Premium / Momentum) — Purdue L1 (Basic Controllers)

Direct attack surface (per vendor docs): Modbus/TCP 502, UMAS function code 0x5A tunneled over Modbus, FTP 21 (default-on for firmware download on legacy Quantum/M340), HTTP 80 embedded web server (FactoryCast), SNMP 161, BOOTP/DHCP, EtherNet/IP 44818 on -E variants, IPsec optional on M580. Historically ships with a hardcoded FTP recovery account and a UMAS reservation cookie that is trivially predictable.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2018-7841	9.8	Modicon Quantum	UMAS auth bypass via web server	research only
CVE-2021-22779	8.1	M340/M580/Quantum/Momentum	UMAS reservation bypass ("ModiPwn", Claroty)	research only
CVE-2020-7475	7.5	M580	Hardcoded FTP credential	research only
CVE-2022-45788	7.5	Modicon M340/M580	UMAS undocumented Memory Write (Forescout OT:ICEFALL)	research only
Schneider PSIRT 2024 Modbus/UMAS DoS family	n/a	Modicon M580 / Momentum	Modbus UMAS DoS via crafted packet (see Schneider PSIRT)	research only

Top attack vector (MITRE ATT&CK ICS): T0855 Unauthorized Command Message via UMAS function 0x5A; supported by T0843 Program Download.

Group B — EcoStruxure Control Expert + Operator Terminal Expert — Purdue L3 (Site Operations, EWS)

Direct attack surface (per vendor docs): Windows engineering workstation; project files (`.stu` , `.xef` , `.zef` , `.apx`) are ZIP-archived XML with embedded compiled IL — historically deserialized without signature check. Talks to PLCs over UMAS/Modbus 502 and proprietary Schneider OFS OPC server. Vijeo Designer additionally exposes runtime download over TCP 6000.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2020-7559	7.8	EcoStruxure Control Expert	DLL hijack at engineering workstation startup	research only
CVE-2021-22779	8.1	Control Expert ↔ PLC	UMAS session hijack from EWS	research only
Schneider PSIRT 2023 Control Expert project-file RCE	n/a	EcoStruxure Control Expert	RCE via crafted `.stu` project (Armis-class; see Schneider PSIRT)	research only
Claroty Team82 "Evil PLC" class	n/a	Control Expert	Weaponized PLC pushes payload to EWS on upload	research only

Top attack vector (MITRE ATT&CK ICS): T0873 Project File Infection — EWS opens a tampered `.stu`, attacker pivots to OT.

Group C — Triconex SIS (Tricon / Trident / Tri-GP) — Safety Systems (parallel to L1)

Direct attack surface (per vendor docs and Dragos/Mandiant TRITON reports): TriStation protocol UDP/1502 between TS1131 EWS and MP module; no authentication, no signing of downloaded function blocks. Key-switch (PROGRAM/RUN/REMOTE) is the only mandatory defense — TRITON exploited installations left in PROGRAM during commissioning. Tricon v10.0–10.4 has a documented memory-read primitive that the TRITON `trilog.exe` framework abused to inject the `imain.bin` implant onto the MP.

Confirmed CVEs / threat-intel anchors:

CVE	CVSS	Product	Vector	Status
CVE-2018-8872	7.5	Tricon MP 3008	OOB memory read used by TRITON	research only
TRITON/TRISIS framework (XENOTIME)	n/a	Tricon	Implant `trilog.exe` → `inject.bin` → `imain.bin` on MP	Dragos report
ICSA-18-107-02	n/a	Triconex Tricon	CISA advisory tied to TRITON	research only

Top attack vector (MITRE ATT&CK ICS): T0857 System Firmware — TRITON wrote a new firmware image to the SIS controller; combine with T0858 Change Operating Mode.

Group D — Citect SCADA / Plant SCADA — Purdue L3 (Site Operations)

Direct attack surface (per vendor docs): Citect server uses CTAPI on TCP 5482, IOServer on configurable port, Cicode runtime inside the server process. Project files (`.ctz`) are ZIPs with Cicode source — same project-file-infection class as Group B. Historically vulnerable ODBC stack and a documented stack overflow in the ANL parser.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2008-2639	10.0	CitectSCADA	ODBC server stack overflow (Core Security)	research only
CVE-2020-7548	7.8	Citect Anywhere	Auth bypass	research only
Schneider PSIRT 2023 Plant SCADA path traversal family	n/a	Plant SCADA (EcoStruxure)	Authenticated path traversal (see Schneider PSIRT)	research only

Top attack vector (MITRE ATT&CK ICS): T0853 Scripting — Cicode payload embedded in a tampered `.ctz` project.

Group E — EcoStruxure Power Operation / Power Monitoring Expert / Sepam relays — Purdue L3 SCADA (Power Operation / PME) + L1 IED (Sepam, incl. IEC 61850 station bus)

Direct attack surface (per vendor docs): Power Operation = Windows SCADA stack (ex-Citect codebase). Sepam relays expose Modbus RTU/TCP for protection settings, IEC 61850 MMS on TCP 102 with optional MES card, and a serial console for firmware load. Sepam 20/40 series has a documented credentials-in-clear issue.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2018-7790	7.5	Sepam 20/40/60/80	Auth bypass on Modbus port	research only
CVE-2021-22722	7.5	EcoStruxure Power Monitoring Expert	Improper privilege management	research only
Schneider PSIRT 2023 PME report-generator RCE family	n/a	Power Monitoring Expert	RCE via report generator (see Schneider PSIRT)	research only

Top attack vector (MITRE ATT&CK ICS): T0836 Modify Parameter — alter Sepam protective relay setpoints to defeat fault clearing.

Group F — EcoStruxure cloud agents — Purdue L3 on-prem edge + L3.5 IDMZ traversal + L4/L5 cloud egress (Azure IoT Hub)

Direct attack surface (per vendor docs): Linux gateway (Augmented Operator Advisor / Secure Connect Advisor) phoning home to Azure IoT Hub on TCP 8883 (MQTT/TLS) and 443; bundled OpenSSL, BusyBox, and Node.js runtime — typical Linux-IoT supply-chain surface. Local config web UI on TCP 8080/8443.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2022-32525	9.8	Easergy P5 / EcoStruxure Asset Advisor	Hardcoded SSH key	research only
EcoStruxure cloud-pair bearer-token family (2025 research)	n/a	EcoStruxure agent	Bearer-token mishandling in cloud-pair flow (see Schneider PSIRT)	research only

Top attack vector (MITRE ATT&CK ICS): T0884 Connection Proxy — cloud agent itself becomes the C2 tunnel into the OT cell.

Logging matrix (highest priority)

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Modbus/UMAS sensor (Snort/Suricata/Zeek)	UMAS function 0x5A from non-EWS host	UMAS auth-bypass / ModiPwn exploitation against Group A	T0855
2	PLC diagnostic buffer (M580 SYSLOG, FactoryCast log)	Reservation cookie reuse, anonymous reservation	Active session hijack of Modicon	T0859 Valid Accounts
3	Windows EWS (Sysmon ID 1/11)	`ControlExpert.exe` spawning `cmd.exe` or writing `.stu` outside project dir	Evil-PLC / project-file infection	T0873
4	TriStation protocol monitor	UDP/1502 traffic from any host other than the designated TS1131 EWS	TRITON-class reconnaissance/implant	T0857
5	Triconex key-switch state	Key-switch left in PROGRAM during normal operation	Configuration drift that enabled TRITON	T0858
6	Citect server (Windows Security 4688)	`Citect32.exe` loading unexpected DLL or opening `.ctz` from temp/downloads	Cicode-laden project file	T0853
7	Sepam relay event log / IEC 61850 GOOSE monitor	Setpoint write to protection element, Modbus write to register bank 0x3000–0x3FFF	Relay parameter modification	T0836
8	Cloud-agent egress (firewall NetFlow)	EcoStruxure gateway connecting to non-Azure FQDN on 8883/443	Hijacked Secure Connect Advisor tunnel	T0884

Secondary:

- Firewall egress: alert on any PLC subnet host opening outbound 443 (no PLC should browse the internet).
- Vendor-native audit: EcoStruxure Control Expert "operator screen" event log + M580 cybersecurity event log (`SECEVT`) — both ship to syslog when configured.
- OT-native power/process anomalies: SOE (sequence-of-events) recorder from the substation RTU; correlate Sepam trip events with relay setpoint writes in window T−60s.
- Physical: Tricon key-switch state telemetry, M580 USB-port enable bit.

- AD: monitor service accounts used by Citect / Power Operation for interactive logons (they should be service-only).

Specific zero-day-ish concerns for your dataset

1. **No Schneider firmware in `firmware-staging\Schneider\` yet.** Highest-priority pulls: M580 ePAC firmware bundle (the embedded Linux side, not VxWorks MP), TriStation 1131 installer (contains the protocol stack on the EWS side and is the easier path to an unauthenticated TriStation fuzzer), and a Sepam 80 firmware blob for IEC 61850 stack triage.
2. **UMAS function-code surface is under-mapped.** Forescout OT:ICEFALL identified multiple undocumented UMAS subfunctions in 2022; a static scan of any Modicon firmware should enumerate the dispatch table and diff against the documented set — anything not in the public list is presumed unauth-reachable until proven otherwise.
3. **Triconex framework reuse risk.** TRITON's `inject.bin` / `imain.bin` were built against Tricon v10.0–10.4; v11.x changed memory layout but kept the same TriStation wire format. Any captured Tri-GP or Trident firmware should be diffed against the leaked TRITON symbols to detect whether the same primitives still exist.
4. **EcoStruxure cloud agents are the soft entry to air-gapped sites.** Secure Connect Advisor is a Linux gateway that holds Azure IoT Hub tokens and a persistent reverse tunnel — extracting one yields the cloud-pair protocol, hardcoded CAs, and likely the same OpenSSL/BusyBox versions Schneider ships across the EcoStruxure line. Prioritize this image over any individual PLC.

Sources

- CISA ICS Advisory ICSA-18-107-02 (Triconex/TRITON): https://www.cisa.gov/news-events/ics-advisories/icsa-18-107-02
- CISA ICS Advisory ICSA-21-138-01 (Modicon UMAS / ModiPwn): https://www.cisa.gov/news-events/ics-advisories/icsa-21-138-01
- CISA ICS Advisory ICSA-22-228-04 (OT:ICEFALL — Schneider): https://www.cisa.gov/news-events/ics-advisories/icsa-22-228-04
- Schneider Electric PSIRT / Cybersecurity Support Portal: https://www.se.com/ww/en/work/support/cybersecurity/vulnerability-policy.jsp
- Claroty Team82 "ModiPwn" research (CVE-2021-22779): https://claroty.com/team82/research/the-race-to-native-code-execution-in-plcs
- Claroty Team82 "Evil PLC Attack" (Schneider EcoStruxure Control Expert): https://claroty.com/team82/research/evil-plc-attack-weaponizing-plcs
- Forescout OT:ICEFALL report (Schneider Modicon UMAS): https://www.forescout.com/research-labs/ot-icefall/
- Dragos XENOTIME / TRITON profile: https://www.dragos.com/threat/xenotime/
- Mandiant/FireEye TRITON technical analysis: https://www.mandiant.com/resources/blog/attackers-deploy-new-ics-attack-framework-triton
- NVD CVE-2018-7841 (Quantum UMAS): https://nvd.nist.gov/vuln/detail/CVE-2018-7841
- NVD CVE-2021-22779 (ModiPwn): https://nvd.nist.gov/vuln/detail/CVE-2021-22779

- NVD CVE-2022-45788 (Modicon undocumented Memory Write): https://nvd.nist.gov/vuln/detail/CVE-2022-45788
- NVD CVE-2018-8872 (Tricon OOB read): https://nvd.nist.gov/vuln/detail/CVE-2018-8872
- NVD CVE-2018-7790 (Sepam auth bypass): https://nvd.nist.gov/vuln/detail/CVE-2018-7790
- NVD CVE-2022-32525 (Easergy/EcoStruxure hardcoded SSH key): https://nvd.nist.gov/vuln/detail/CVE-2022-32525
- MITRE ATT&CK ICS T0855 Unauthorized Command Message: https://attack.mitre.org/techniques/T0855/
- MITRE ATT&CK ICS T0857 System Firmware: https://attack.mitre.org/techniques/T0857/
- MITRE ATT&CK ICS T0873 Project File Infection: https://attack.mitre.org/techniques/T0873/
- MITRE ATT&CK ICS T0836 Modify Parameter: https://attack.mitre.org/techniques/T0836/

SAGE RTU + PowerLink G3 — extracted firmware — 2026-10-22

Acquired from Schneider's **public** Software & Firmware download facet on `se.com` (no login), while searching for TAC Xenta. **Neither package is Xenta** — the search term `911` matched unrelated product lines. Recording them anyway: one is a substation RTU, which is a higher-consequence device class than the Xenta gateways originally wanted.

Package	Product	Files	Distinct SHA256
`C3414-500-S02L0_Firmware_Update.zip`	**SAGE RTU** (ex-Telvent) SCADA remote terminal unit	295	153
`500 Level Controller Firmware Files.7z`	**PowerLink G3 / NF500 G3** lighting controller (Square D)	9	9

PowerLink G3 was **100% already known to VirusTotal** (9 of 9). SAGE was not: 42 of 142 non-key files known, **100 submitted as new baseline**.

SAGE RTU platform

Property	Value
Kernel	`vxWorks`, 6,869,899 B — **ELF 32-bit LSB, Intel i386, statically linked**
OS	**VxWorks 6.9**, build `Cougar_VSB_69412_K6P2` → **6.9.4.12**
Application	`C3414-500-S02L0.out` (3,083,136 B, ELF relocatable, **not stripped**)
Web/CLI	`WebCLI` (2,023,328 B, ELF relocatable, **with debug_info**)
Services	`VxWorks login:` prompt, `220 Wind River FTP server %s ready.`
Build path leak	`V:/Workspace/Cougar_VxWorks_996L0`
Vendor string	`Copyright 1984-2004 Wind River Systems, Inc.`

URGENT/11 — stack present, version at the fix line, patch status undetermined

The **Interpeak IPnet stack that URGENT/11 targets is present**: 1,850 `ipnet`, 2,061 `ipcom` and 16 `Interpeak` references in the kernel image. URGENT/11 affects **VxWorks 6.5 and later**, and Tenable's detection treats **6.9.4** as the fixed baseline.

This build is **6.9.4.12**, i.e. **at or above that line**. So the honest reading is: *the vulnerable component ships, and the version is not below the published fix threshold.* **Whether this specific maintenance build carries the July-2019 URGENT/11 patches cannot be determined from version strings alone** — 6.9.4.x point releases span both sides of that date, and Wind River issued per-release patches rather than a single version bump. Confirming it needs Wind River's advisory or Schneider's product bulletin. **No CVE is asserted as applicable here**; this is a flagged candidate, not a finding.

Shipped private key material — the significant finding

The update package contains **private keys**, and the same RSA private key is **byte-identical across four bundled locations**:

Key	SHA256 (first 16)	Locations
`rsa_pvt.key`	`613e04dd11bb4200`	`SSH/RTU_keys/`, **and all three** `*_USERS.tar.gz` bundles
`Admin_OpenSSH_private.key`	`b2c73d113e1656d1`	`SSH/Admin_keys/`
`SSL/server.key`	`c76143753d9ecbde`	`SSL/`

Also present: `Admin_no_password.ppk` (a PuTTY key explicitly without a passphrase), `dsa_pvt.key`, and named user keys `DeanLopez.pk2` / `DeanUser.pk2` — personal names, which suggests this package was assembled from a working environment rather than from sanitised templates.

`SSL/server.crt` is **self-signed**:

```
subject = C=US, ST=Texas, L=Houston, O=Telvent, OU=RTU, CN=192.168.1.1
issuer  = (same - self-signed)
valid   = 2012-03-30  ->  2042-03-30     (30-year lifetime)
SHA256  = 16:AD:C5:7C:BE:F2:F4:E8:07:C4:8B:18:2F:D3:61:AF:78:77:C0:A6:E8:20:31:9A:AF:C8:7D:E3:97:4C:0
```

`CN=192.168.1.1` is a default device address, not a hostname, so the certificate cannot meaningfully authenticate any particular RTU.

Why the duplication matters. A host key that is identical in `RTU_keys/` *and* in every bundled `USERS` configuration is a **shipped default**, not per-deployment material. Any RTU provisioned from these bundles presents the same SSH host key, so host-key verification cannot distinguish a real RTU from an impersonator, and anyone holding this public package holds that key.

Confirmed vs not confirmed. Confirmed: the key is byte-identical in four locations inside this publicly downloadable package, and **all 11 key files are already present in VirusTotal**, so the material has been circulating. Not confirmed: that any deployed ARNG RTU actually uses these keys — operators may regenerate on commissioning, and one bundle is named `SAGERTU_Class_Example_1`, which reads like training material. **The check worth running is on real devices: compare the live SSH host-key fingerprint against**

the shipped key. That is a cheap, decisive test and it converts this from a packaging observation into a finding.

Handling note

Key material is catalogued but **excluded from VT submission** by keeping it out of `catalog.csv` (the file the submit orchestrator reads) and listing it in `KEY-MATERIAL-DO-NOT-SUBMIT.csv`; the full inventory is preserved in `catalog-full-including-keys.csv`. Submitting private keys to a sample-sharing service is an irreversible republication, and it was not needed here — VirusTotal already holds all 11.